ACTIVIDAD 7

Puerto 23 (Telnet) - Credenciales en Texto Plano - Metasploitable

Python y Ciberseguridad

Antes de empezar...	
Nombre	Iker
Apellidos	Martinez Bermudez
Fecha	

Resultados de Aprendizaje

RA2 - Identifica las principales amenazas digitales y los vectores de ataque más habituales, y aplica mecanismos de protección de la información adecuados a cada tipo de riesgo.

2. Identifica y clasifica las principales amenazas y vulnerabilidades que pueden afectar a sistemas informáticos, relacionando cada tipo de ataque con contramedidas concretas.

4. Describe el funcionamiento de los mecanismos de cifrado simétrico (AES) y asimétrico (RSA), comprende sus diferencias y aplica cada uno al contexto de uso adecuado.

RA3 - Analiza el tráfico de red para identificar patrones de comunicación y detectar comportamientos anómalos o sospechosos mediante herramientas de monitorización.

3.1 Diferencia los principales protocolos de red (TCP/UDP, HTTP/HTTPS, DNS, FTP, SSH) identificando sus características, puertos y nivel de seguridad.

Contexto

En el escaneo de puertos de Metasploitable que hiciste en la práctica anterior, detectaste que el **puerto 23 está abierto con el servicio Telnet**. Para confirmar, ejecuta de nuevo el comando de detección de versiones:

```
nmap -sS -sV -O <IP_de_Metasploitable>
```

El servidor acepta conexiones con las credenciales por defecto: **msfadmin / msfadmin**. Pero el problema no está solo en la contraseña débil...

PROBLEMA: Telnet **NO cifra las comunicaciones**. Todo el tráfico — incluyendo usuario, contraseña y comandos ejecutados — viaja en **texto plano** por la red. Cualquier persona en la misma red puede interceptarlo con un sniffer.

Preparación del entorno

Antes de empezar, verifica que tienes:

- **Máquina víctima:** Metasploitable 2 ejecutándose
- **Red:** Adaptador **host-only**
- **Máquina Atacante:** Kali Linux / Ubuntu con las siguientes herramientas instaladas:
  - Wireshark (si no está instalado: `sudo apt-get install wireshark`)
  - Telnet client (si no está instalado: `sudo apt-get install telnet`)
  - Netcat (si no está instalado: `sudo apt-get install netcat-traditional`)
- Red:
  - **Adaptador 1 host-only** (misma red que Metasploitable)
  - **Adaptador 2 NAT** (para Internet)

Actividades

PARTE 1: Análisis de protocolos - Telnet vs SSH

Antes de capturar tráfico, vamos a entender qué diferencia hay entre los dos protocolos.

Investiga y responde las siguientes preguntas (puedes buscar en Internet):

- ¿Qué protocolo de transporte usa Telnet? (TCP / UDP) ¿En qué puerto?
  Usa el protocolo TCP en el puerto 23.

- ¿Qué protocolo de transporte usa SSH? ¿En qué puerto?

  Usa el protocolo TCP en el puerto 22.

- ¿Qué significa que un protocolo funcione en **texto plano**? Pon un ejemplo cotidiano.

  Significa que la información se transmite sin ningún tipo de cifrado o codificación de seguridad.

  Un Ejemplo cotidiano seria

  Enviar una tarjeta postal por correo; cualquier persona que la maneje en el trayecto puede leer el mensaje escrito porque no está dentro de un sobre cerrado.

- ¿Qué principio de la CIA se vulnera al usar Telnet? (Confidencialidad / Integridad / Disponibilidad)

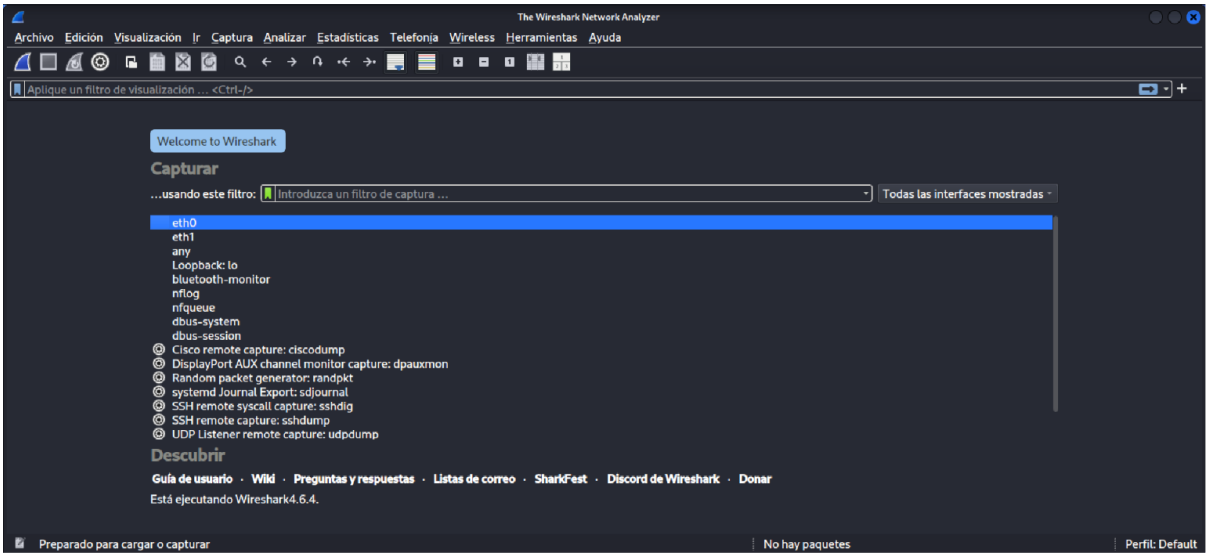
  Se vulnera la Confidencialidad, ya que los datos son legibles para terceros no autorizados.

PARTE 2: Conexión por Telnet y captura con Wireshark

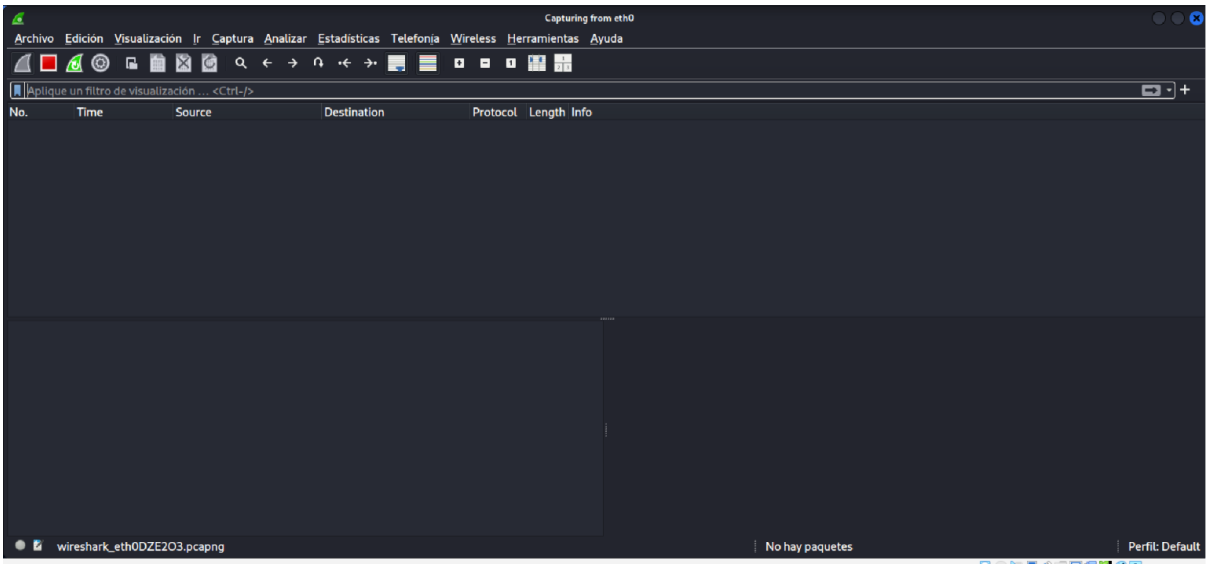
Vamos a conectarnos a Metasploitable usando Telnet mientras **Wireshark captura el tráfico**. Así podrás ver con tus propios ojos cómo las credenciales viajan sin cifrar.

Paso 1: Inicia la captura en Wireshark

1. Abre Wireshark en tu Kali/Ubuntu.

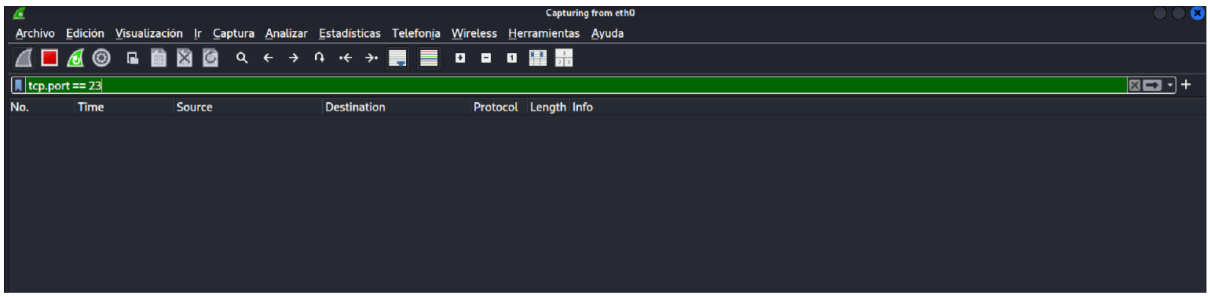


2. Selecciona la interfaz de red **host-only** (normalmente eth1, enp0s8 o similar).
3. Inicia la captura haciendo clic en el botón **Start capturing packets** (icono de tiburón azul).



4. Aplica el filtro para ver solo tráfico Telnet. Escríbelo en la barra de filtros y presiona enter:

```
tcp.port == 23
```



Captura de pantalla 1: Wireshark con la captura iniciada y el filtro tcp.port == 23 aplicado.

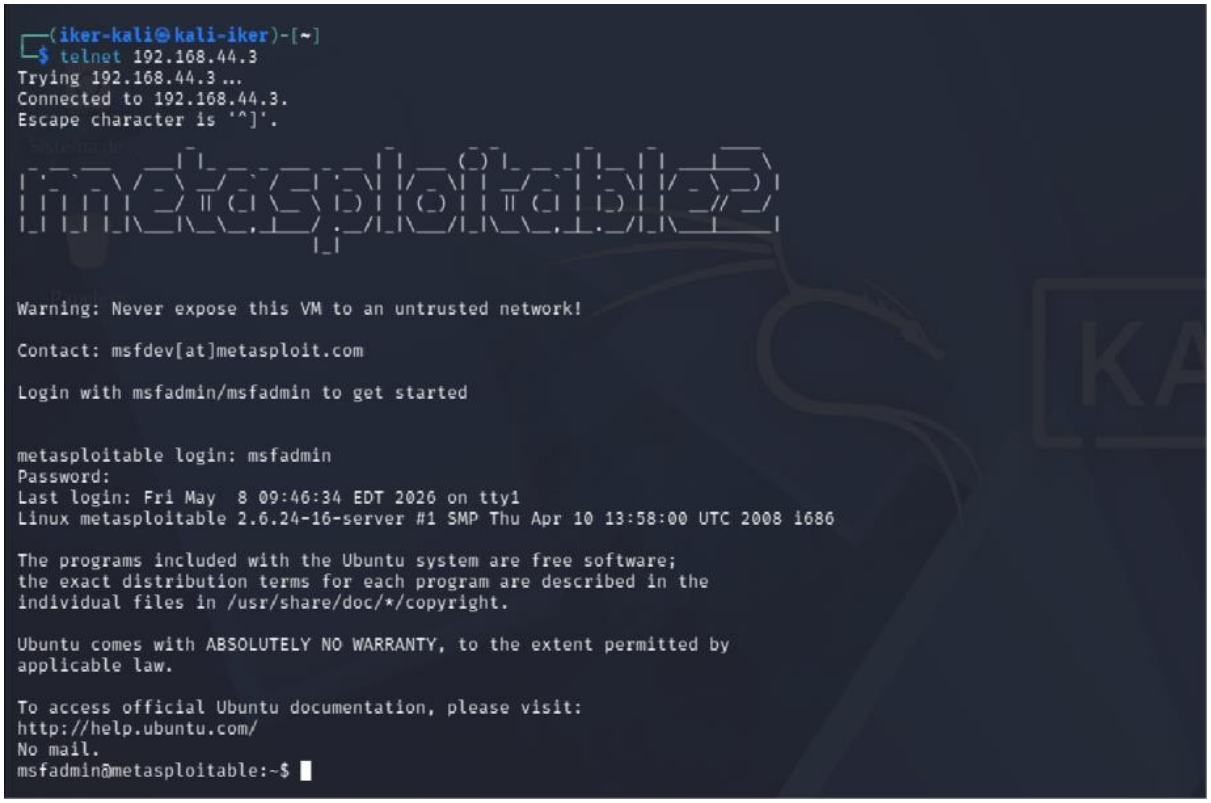
Paso 2: Conéctate a Metasploitable por Telnet

Abre una terminal en Kali/Ubuntu y ejecuta:

```
telnet <IP_de_Metasploitable>
```

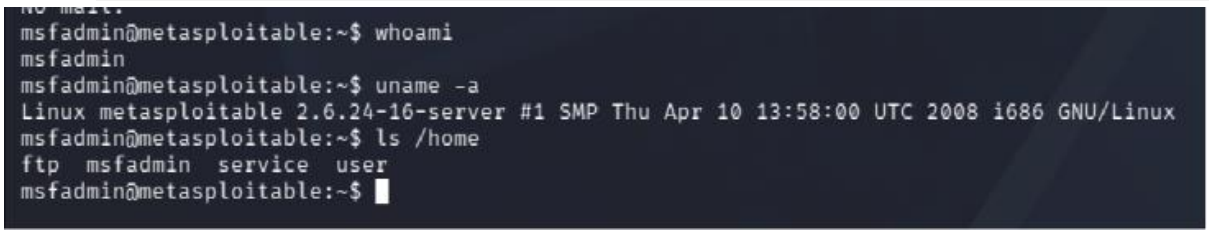
Cuando te pida credenciales, introduce:

```
login: msfadmin
Password: msfadmin
```



Una vez dentro, ejecuta algunos comandos para generar tráfico:

```
whoami
uname -a
ls /home
```



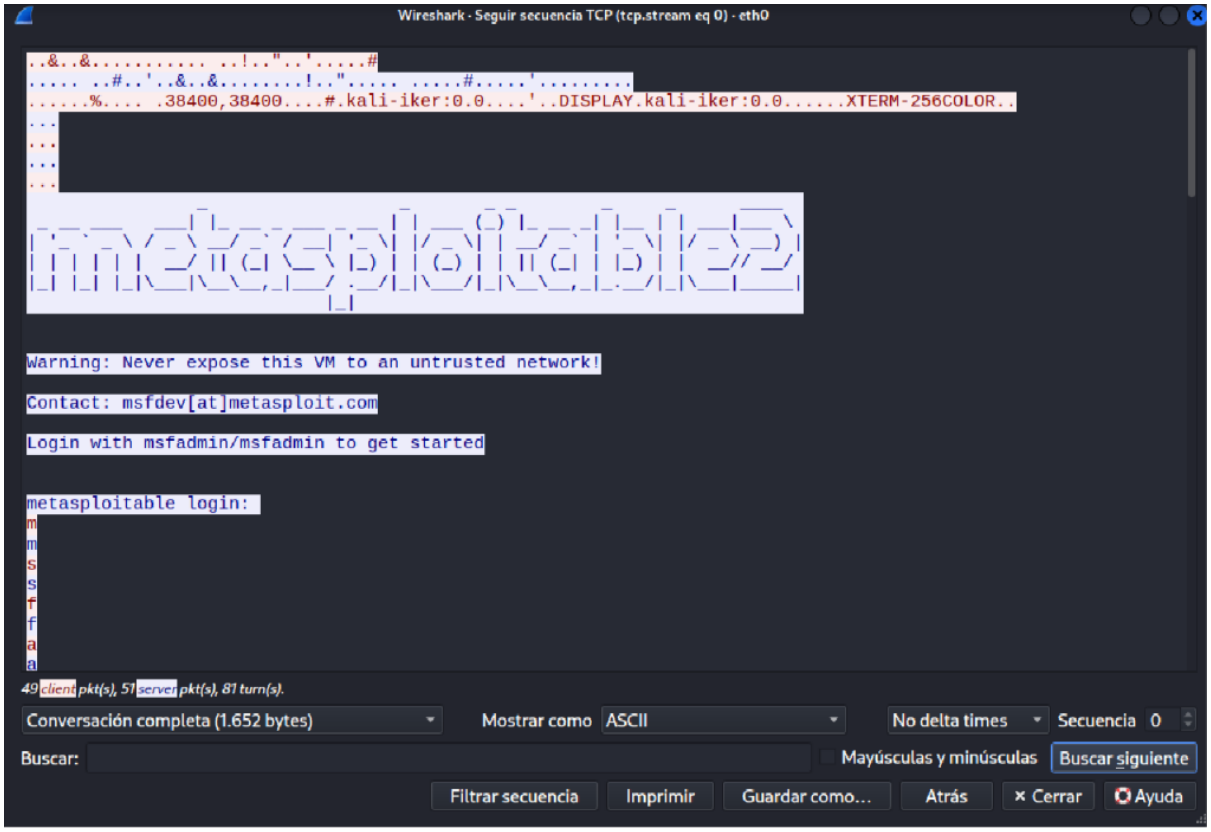
Captura de pantalla 2: Terminal Telnet conectada a Metasploitable con los comandos ejecutados.

Paso 3: Analiza el tráfico capturado

Vuelve a Wireshark. Deberías ver paquetes capturados. Haz clic derecho en uno y selecciona:

```
Follow > TCP Stream
```

Esto mostrará **toda la conversación TCP en texto legible**. **Busca tus credenciales en la captura** — las verás en texto plano.



Captura de pantalla 3: Ventana TCP Stream de Wireshark mostrando las credenciales de Telnet en texto plano.

Responde:

- ¿Qué riesgo representa esto en una red corporativa?

Oye, pues mira, el riesgo de usar Telnet en una empresa es que es un coladero de seguridad porque no cifra nada. Básicamente, cualquier cotilla que esté en la misma red puede usar un sniffer para interceptar tus claves y verlas en texto plano, sin ningun esfuerzo. Esto rompe totalmente la Confidencialidad, por que tus contraseñas van "al desnudo" por el cable. Si un atacante pilla el usuario y la pasword del admin, ya tiene las llaves de todo el sistema y puede mangar datos sensibles. Al final, estas dejando la

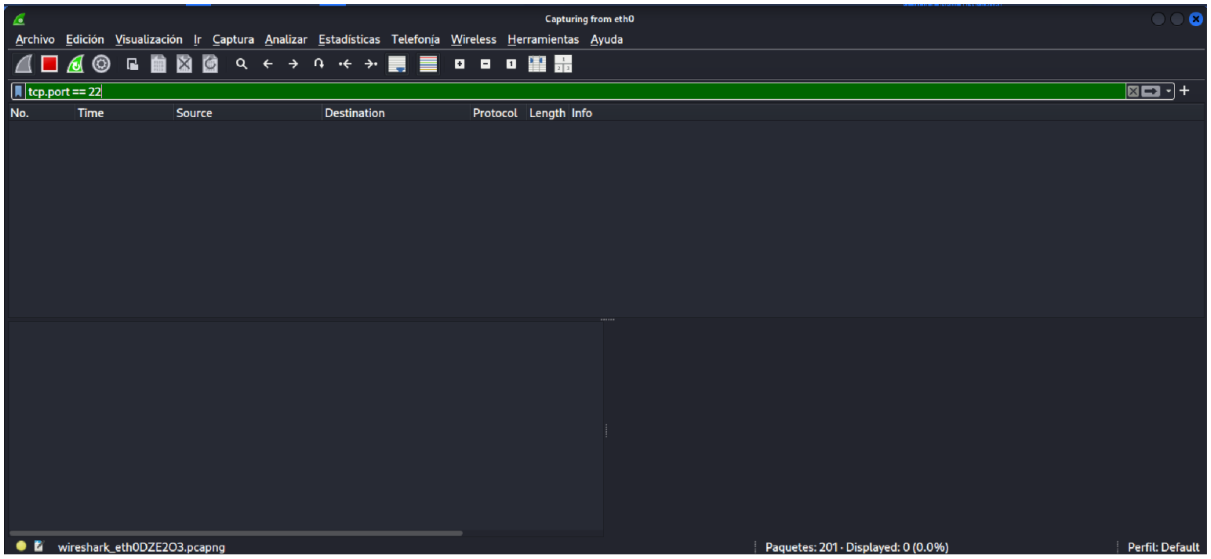
puerta abierta a que escalen privilegios o se muevan por toda la red corporativa como Pedro por su casa. Por eso, lo suyo es chapar el puerto 23 y usar siempre SSH, que si que va cifrado y no se ve nada de nada.

PARTE 3: Comparación con SSH (tráfico cifrado)

Ahora vamos a repetir el proceso pero usando **SSH** para ver la diferencia.

1. En Wireshark, cambia el filtro a:

```
tcp.port == 22
```



2. Conéctate a Metasploitable por SSH desde tu Kali/Ubuntu:

```
ssh msfadmin@<IP_de_Metasploitable>
```

```
msfadmin@metasploitable:~$ ssh msfadmin@192.168.44.3
The authenticity of host '192.168.44.3 (192.168.44.3)' can't be established.
RSA key fingerprint is 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.44.3' (RSA) to the list of known hosts.
msfadmin@192.168.44.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Fri May  8 09:59:05 2026
msfadmin@metasploitable:~$ ssh msfadmin@192.168.44.3
msfadmin@192.168.44.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
```

No me ha salido el error Atención: si este comando te da un error de:

```
  Unable to negotiate with 192.168.56.10 port 22: no matching host
key type found. Their offer: ssh-dss
```

Anade el comando *-oHostKeyAlgorithms=+ssh-dss:* es necesario debido a una diferencia en los algoritmos de cifrado utilizados por diferentes versiones de ssh:

```
  ssh -oHostKeyAlgorithms=+ssh-dss msfadmin@<IP_de_Metasploitable>
```

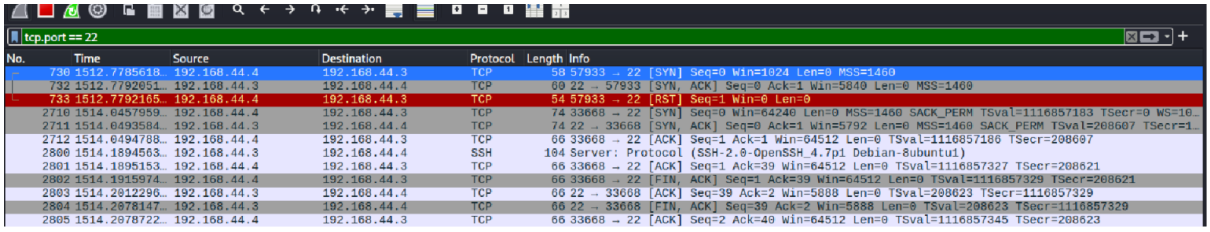
Acepta la clave del host (yes) e introduce la contraseña: **msfadmin**

3. Ejecuta los mismos comandos que antes:

```
whoami
uname -a
ls /home
```

```
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ ls /home/
ftp  msfadmin  service  user
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$
```

4. Vuelve a Wireshark y sigue el TCP Stream del tráfico SSH.



Captura de pantalla 4: TCP Stream de Wireshark con tráfico SSH — mostrando datos cifrados ilegibles.

Responde:

- ¿Puedes ver las credenciales en el tráfico SSH? ¿Por qué?

  No, no se puede ver absolutamente nada de las credenciales en el tráfico SSH. Esto pasa por que, a diferencia del Telnet que lo manda todo "al desnudo" en texto plano, el protocolo SSH cifra toda la comunicacion entre tu equipo y la máquina Metasploitable. Al usar algoritmos de cifrado, los datos se vuelven un jaleo de símbolos y carácteres raros que son imposibles de leer si los miras con Wireshark. Básicamente, se proteje la Confidencialidad por que la pasword y los comandos viajan protegidos de cualquier cotilla que este husmeando en la red. Por eso, aunque le des a lo de Follow TCP Stream, solo verás datos cifrados que no tienen ningun sentido.

PARTE 4: Solución - Deshabilitar Telnet

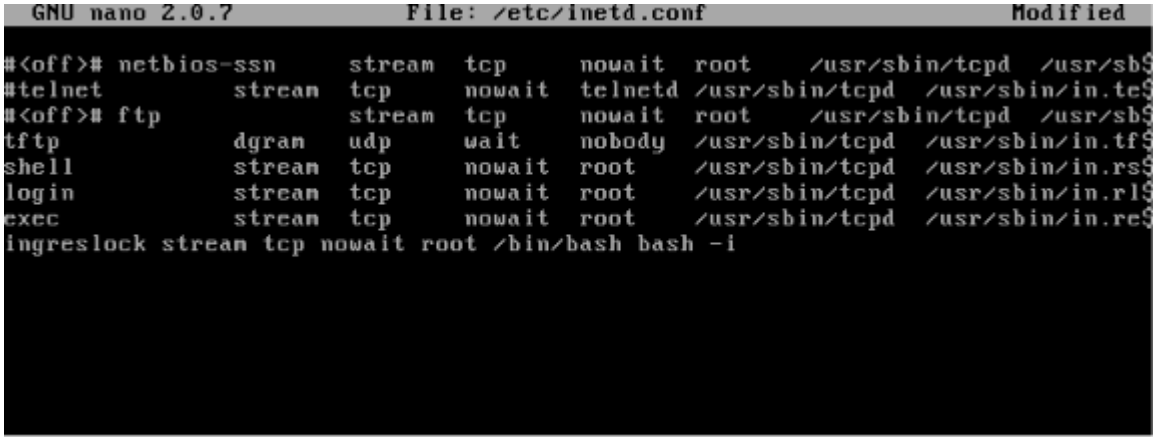
Ahora que has demostrado el riesgo, aplicamos la contramedida: **eliminar Telnet**.

1. En Metasploitable, deshabilita el servicio Telnet:

```
sudo nano /etc/inetd.conf
```

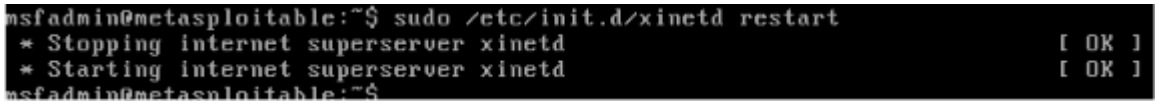
Busca la línea que contiene `telnet` y añade **#** al principio para comentarla (desactivarla):

```
#telnet  stream  tcp  nowait  telnetd  /usr/sbin/tcpd
/usr/sbin/in.telnetd
```



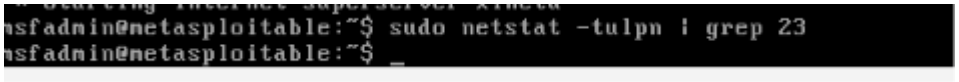
Guarda el archivo y reinicia el servicio xinetd:

```
sudo /etc/init.d/xinetd restart
```



2. Verifica que el puerto 23 ya no está en escucha:

```
sudo netstat -tulpn | grep 23
```

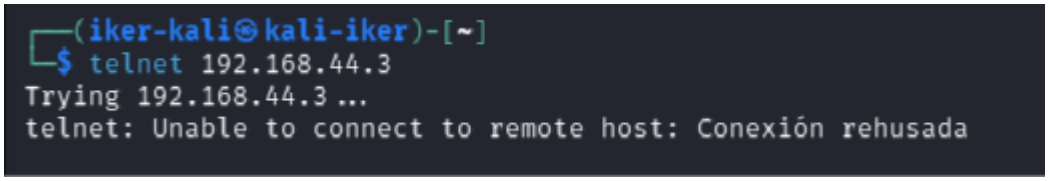


El puerto 23 **NO debería aparecer**.

Captura de pantalla 5: Salida de netstat mostrando que el puerto 23 ya no está en LISTEN.

3. Intenta conectarte de nuevo por Telnet — debería fallar:

```
telnet <IP_de_Metasploitable>
```



Deberías ver `Connection refused` o `Unable to connect`.

Captura de pantalla 7: Intento de conexión Telnet fallando — "Connection refused".

Entregables

Este documento completado con todas las respuestas, capturas de pantalla y el documento de política de seguridad.